

Critical Infrastructure Compromise

Network Malware Traffic Analysis Report

Author: Amin M.Fathallah – All rights reserved

Date: June 13, 2025

Severity:  Critical

Prepared by: Security Traffic Analysis (SOC-Level Investigation)

1. Executive Summary

A sophisticated malware-based attack was identified targeting a **critical internal asset (Domain Controller)** within the corporate network.

The investigation revealed a **malicious download from a disguised external server**, followed by **encrypted Command-and-Control (C2) communications** and **confirmed data exfiltration activity**.

Due to the victim system's role in **authentication and directory services (LDAP, Kerberos)**, the incident represents a **high-risk compromise** with potential domain-wide impact.

Business Impact: Potential business impact includes: full Active Directory compromise, credential theft, lateral movement, and business service disruption.

2. Investigation Scope & Methodology

This investigation followed SOC and DFIR best practices to ensure forensic integrity and reproducibility.

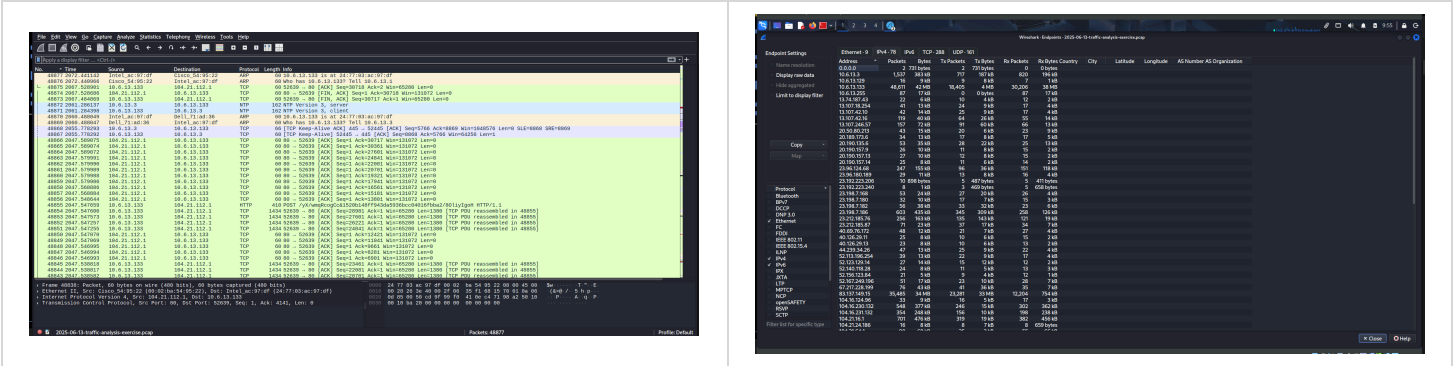
2.1 Evidence Acquisition

- Original capture file: 2025-06-13-traffic-analysis-exercise.pcap
- Treated as **read-only forensic evidence**
- Initial inspection performed using **Wireshark** to validate integrity and identify anomalies

Steps Taken:

- 1. Verified PCAP file integrity and completeness
- 2. Extracted initial statistics: total packets, duplicates, missing values
- 3. Applied Wireshark filters to isolate suspicious traffic
- 4. Developed and executed Python/Scapy script to structure raw traffic
- 5. Validated CSV output and cross-checked with IOCs

 Screenshot: Initial Wireshark traffic overview



2.2 Traffic Exploration & IOC Discovery

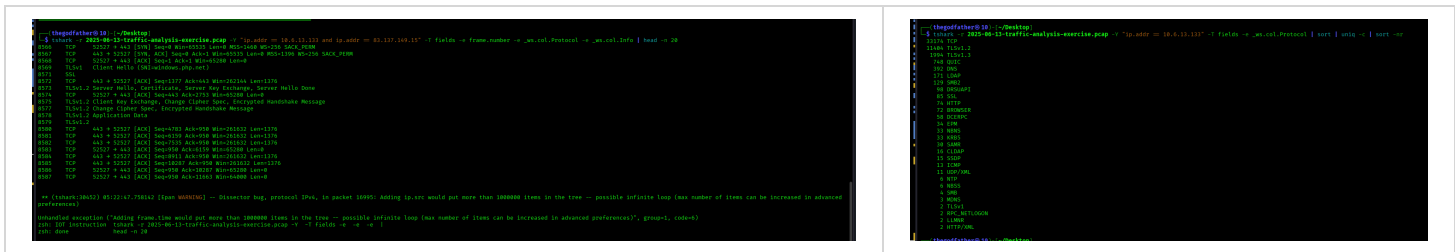
Wireshark protocol and display filters were applied to isolate:

- High-volume TCP/TLS sessions
- HTTP POST requests
- Suspicious DNS queries

Key IOCs Identified:

- **Malicious IP:** 83.137.149.15
- **Suspicious Domains (Typosquatting / Look-alike):**
 - event-datamicrosoft.live
 - eventdata-microsoft.live
 - event-time-microsoft.org

 Screenshot: Filtered malicious traffic



2.3 Data Extraction & Feature Engineering

A custom **Python (Scapy)** script was developed to convert raw PCAP traffic into structured data.

Extracted Fields:

- Timestamp
- Source IP / Destination IP
- Source Port / Destination Port
- Protocol
- Packet Length

Output File: malware_traffic_extracted.csv

 *Screenshot: Terminal execution of extraction script*

malware traffic analysis > exports > malware_traffic_extracted.csv								
	timestamp_epoch	src_ip	dst_ip	src_port	dst_port	protocol	packet_length	flow_id
1	1749828835.696551	0.0.0.0	255.255.255.255	68	67	UDP	344	0.0.0.0:68->255.255.255.255:67/UDP
2	1749828835.697566	10.6.13.3	255.255.255.255	67	68	UDP	342	10.6.13.3:67->255.255.255.255:68/UDP
3	1749828835.698061	0.0.0.0	255.255.255.255	68	67	UDP	387	0.0.0.0:68->255.255.255.255:67/UDP
4	1749828835.698643	10.6.13.3	255.255.255.255	67	68	UDP	342	10.6.13.3:67->255.255.255.255:68/UDP
5	1749828835.710271	10.6.13.133	10.6.13.3	61943	53	UDP	81	10.6.13.133:61943->10.6.13.3:53/UDP
6	1749828835.712861	10.6.13.3	10.6.13.133	53	61943	UDP	160	10.6.13.3:53->10.6.13.133:61943/UDP
7	1749828835.714276	10.6.13.133	10.6.13.3	52241	53	UDP	92	10.6.13.133:52241->10.6.13.3:53/UDP
8	1749828835.714359	10.6.13.3	10.6.13.3	53493	53	UDP	81	10.6.13.133:53493->10.6.13.3:53/UDP
9	1749828835.714426	10.6.13.3	10.6.13.133	53	52241	UDP	171	10.6.13.3:53->10.6.13.133:52241/UDP
10	1749828835.715161	10.6.13.133	224.0.0.252	54131	5355	UDP	75	10.6.13.133:54131->224.0.0.252:5355/UDP
11	1749828835.715457	10.6.13.3	10.6.13.133	53	53493	UDP	160	10.6.13.3:53->10.6.13.133:53493/UDP
12	1749828835.715591	10.6.13.133	10.6.13.3	52241	53	UDP	160	10.6.13.133:52241->10.6.13.3:53/UDP
13	1749828835.717556	10.6.13.3	10.6.13.133	53	52241	UDP	160	10.6.13.3:53->10.6.13.133:52241/UDP
14	1749828835.724271	10.6.13.133	10.6.13.3	53493	53	UDP	128	10.6.13.133:53493->10.6.13.3:53/UDP
15	1749828835.724567	10.6.13.3	10.6.13.133	53	53493	UDP	196	10.6.13.3:53->10.6.13.133:53493/UDP
16	1749828835.734991	10.6.13.133	10.6.13.3	52241	53	UDP	92	10.6.13.133:52241->10.6.13.3:53/UDP
17	1749828835.735134	10.6.13.3	10.6.13.133	53	52241	UDP	188	10.6.13.3:53->10.6.13.133:52241/UDP
18	1749828835.735594	10.6.13.133	10.6.13.3	53497	389	UDP	236	10.6.13.133:53497->10.6.13.3:389/UDP
19	1749828835.735986	10.6.13.133	10.6.13.3	53497	389	UDP	236	10.6.13.133:53497->10.6.13.3:389/UDP
20	1749828835.736156	10.6.13.3	10.6.13.133	389	53497	UDP	218	10.6.13.3:389->10.6.13.133:53497/UDP

2.4 Data Quality & Profiling

Metric	Result
Total Packets	48,615
Missing Values	0
Duplicate Packets	217
Data Integrity	High
Analytics Readiness	

Duplicates were **intentionally retained** to preserve retransmission behavior and **true network load**, critical for forensic accuracy.

3. Attack Narrative (What Actually Happened)

Phase 1: Initial Compromise – Malicious Download

- **Victim Host:** 10.6.13.133 (Domain Controller)
- **Observed Behavior:** Large outbound download (~34–42 MB)
- **Target Name (SNI):** windows.php.net
- **Actual Server IP:** 83.137.149.15

 Analysis:

The attacker used **domain masquerading** to imitate a legitimate PHP download service. Unlike official [php.net](#) infrastructure (CDN-based), the traffic terminated at a **non-CDN VPS-hosted IP**, strongly indicating malware delivery.

Phase 2: C2 Establishment

Post-download, the infected host initiated encrypted communications with:

- **C2 Domain:** event-datamicrosoft.live
- **Method:** HTTP POST
- **Payload Type:** application/octet-stream (Encrypted/Binary)

- **Volume:** ~30 KB per exchange

 Analysis:

The domain imitates Microsoft telemetry services but uses an invalid domain structure (typosquatting).

Phase 3: Command & Control and Data Exfiltration

- **Outbound (Victim → Attacker):** 12,204 packets
- **Inbound (Attacker → Victim):** 23,281 packets
- **Confirmed Exfiltrated Data:** ~0.72 MB (validated via session aggregation and byte count)
- **Traffic Pattern:** Regular, low-variance packet sizes (C2 beaconing)

 Conclusion:

This behavior matches **automated C2 heartbeat + controlled data exfiltration**.

4. Victim & Threat Actor Identification

4.1 Victim Details

Asset	Role	Risk
10.6.13.133	Domain Controller	 Critical
10.6.13.3	Internal Host	Medium

Indicators:

- High RX vs TX ratio
- Kerberos (KRB5), LDAP, DRSUAPI traffic
- Authentication infrastructure involvement

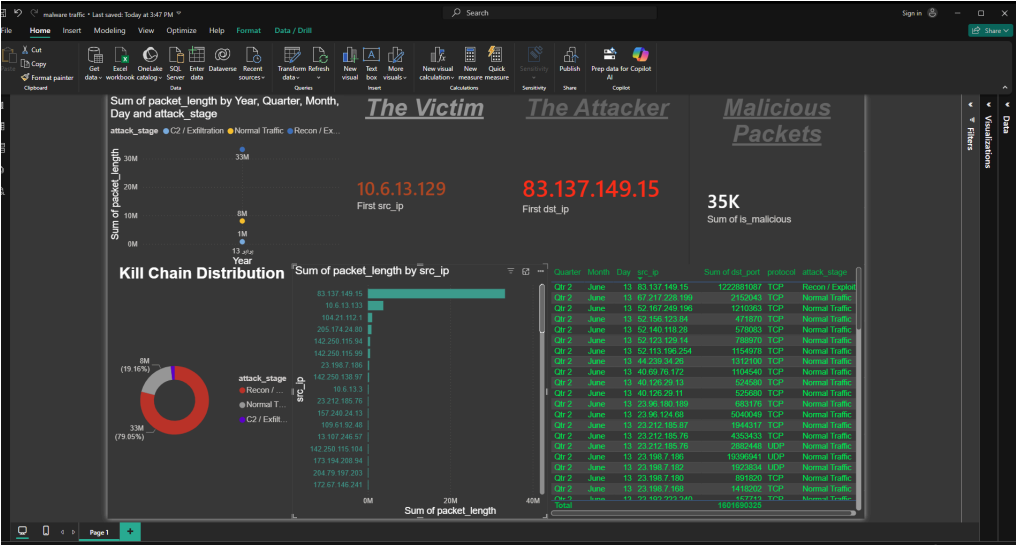
4.2 Threat Actor Infrastructure

Component	Value
Attacker IP	83.137.149.15
Fake Target	windows.php.net
C2 Domain	event-datamicrosoft.live
Encryption	TLSv1.2 / TLSv1.3
Hosting Provider	VPS / Unknown (if available)
ASN / Country	Optional info if known

5. Attack Timeline

Event	Timestamp
Attack Start	2025-06-13 15:36:33
Attack End	2025-06-13 15:38:49
Duration	~2 minutes
Malicious Packets	35,485

 *Screenshot: Power BI Dashboard*



6. Protocol & Weapon Analysis

Protocol	Packet Count
TCP	33,174
TLSv1.2	11,404
TLSv1.3	1,994
QUIC	748
DNS	392
LDAP	171
SMB2	129
HTTP	74

📌 **Insight:**
Encryption dominance (>90%) significantly reduces payload visibility, emphasizing **behavioral detection** and **traffic pattern analysis**.

7. Risk Assessment

Category	Assessment
Asset Criticality	Domain Infrastructure
Attack Type	Malware + C2
Data Exposure	Likely Credentials
Impact Scope	Domain-wide
Severity	● CRITICAL

8. Immediate Response Actions (Required)

8.1 Containment (Immediate)

- **Isolate host** 10.6.13.133 → Prevent lateral movement
- **Block IP:** 83.137.149.15 → Stops ongoing C2 traffic
- **Block domains:**
 - event-datamicrosoft.live
 - eventdata-microsoft.live
 - event-time-microsoft.org
- **Terminate active TLS sessions**

8.2 Forensics & Investigation

- File system scan for artifacts created on 2025-06-13 11:33
- Memory dump analysis for C2 configuration
- Review scheduled tasks, services, and persistence mechanisms

8.3 Credential Protection

- Reset:
 - Domain Admin accounts
 - Service accounts
 - Privileged users
- Enforce MFA immediately
- **Golden Ticket detection & KRBTGT password reset (twice)**

9. Post-Incident Hardening

- Deploy EDR behavioral rules
- Enforce DNS sinkholing
- Block newly registered domains
- Enable TLS inspection where legally possible

- Segment Domain Controllers from user networks

10. Final Conclusion

This incident represents a **targeted compromise of identity infrastructure**, not a simple malware infection.

The attacker successfully:

- Deceived the victim system
- Delivered malicious payloads
- Established encrypted C2 communications
- Initiated data exfiltration

Rapid containment prevented a potential full domain takeover.

Failure to detect this activity earlier highlights the necessity for enhanced behavioral monitoring and encrypted traffic analytics.

End of Report